

Management Information Systems

Class Notes: Classes 33–39

Part II • Sections MIS-5 (cont.), MIS-6, MIS-7 • GDSS/EIS, IS in Business, IS Security & Audit

CO2 — MIS in Business Strategy & Decision Making

CO3 — IS Infrastructure, Ethics & Security

Bloom's: Understand → Analyze → Evaluate

Semester Final: 72 Marks

CONTENTS

- 33 GDSS & Executive Information Systems (EIS)
- 34 Critical Success Factors & TPS/MIS/DSS/EIS Comparison
- 35 Marketing, Manufacturing & HR Information Systems
- 36 Accounting, Financial & Strategic Information Systems
- 37 Computer Security & System Vulnerability
- 38 Security Breaches, Controls & Countermeasures
- 39 IS Audit, Ethics & Course Review

1. GDSS — Group Decision Support System

DEFINITION

A **Group Decision Support System (GDSS)** is an IS that facilitates group decision making by providing a network of connected workstations, structured tools, and anonymous participation mechanisms that enable groups to jointly analyse problems, generate ideas, evaluate alternatives, and reach consensus — faster and with better outcomes than traditional face-to-face meetings.

GDSS TOOLS AND FEATURES

Electronic Brainstorming

All participants simultaneously type ideas into their workstations. Ideas appear on a shared screen in real-time without attribution. Everyone can contribute simultaneously — no waiting for turns, no interruptions.

Benefit: eliminates "production blocking" — in face-to-face meetings, participants lose ideas while waiting to speak. Studies show electronic brainstorming produces 3–5× more unique ideas than oral brainstorming.

Anonymous Input

Participants submit ideas and votes without revealing their identity to the group. The GDSS records who said what (for the facilitator's records) but displays contributions anonymously.

Benefit: junior staff can challenge senior managers without fear; experts give honest opinions without social pressure; reduces political considerations in decision making.

Idea Organization

The GDSS provides tools to categorize, cluster, and rank the ideas generated. Participants can vote on categories, merge similar ideas, and prioritize using weighted scoring.

Benefit: structures unstructured brainstorming output into actionable categories — a list of 200 raw ideas becomes 8 prioritized strategic themes.

Voting & Ranking

Participants electronically vote on alternatives or rank options by preference. GDSS instantly tallies and displays results — no paper ballots, no tallying delays, no ambiguity.

Voting types: simple majority, weighted ranking, Likert scale rating, pair-wise comparison (each option compared to every other). Results displayed as bar charts, ranked lists, or priority matrices.

2. Benefits of GDSS

- ▶ **Reduces groupthink:** Groupthink occurs when group members suppress dissenting views to maintain harmony. GDSS anonymity allows genuine disagreement to surface — a group cannot groupthink what it cannot suppress. Studies of GDSS-supported decisions show fewer conformity errors and higher decision quality.
- ▶ **Anonymity encourages honesty:** Participants express genuine views rather than views shaped by who is in the room. A junior engineer can point out a fatal flaw in the CEO's proposal without career risk.
- ▶ **Parallel input — speed:** All participants contribute simultaneously. A 10-person traditional meeting where each person speaks for 5 minutes takes 50+ minutes for one round of input. GDSS collects all 10 inputs simultaneously in 5 minutes.
- ▶ **Geographic flexibility:** GDSS can connect participants across locations — a team in Dhaka, Chittagong, and Sylhet can participate in the same GDSS session without travel. Modern GDSS platforms integrate with video conferencing.
- ▶ **Automatic documentation:** Every contribution is automatically logged and timestamped — a complete record of the decision process is created without a separate note-taker.
- ▶ **Reduced meeting dominance:** In traditional meetings, 20% of participants typically contribute 80% of spoken content (the "air time" problem). GDSS gives every participant equal input opportunity regardless of personality, seniority, or speaking confidence.

3. EIS — Executive Information System

DEFINITION

An **Executive Information System (EIS)**, also called an **Executive Support System (ESS)**, is an IS specifically designed for top-level executives that provides fast, easy access to both internal performance data and external strategic information in a highly visual, customizable format, supporting unstructured strategic decisions.

4. Rationale for EIS

Why do executives need a specialized IS separate from MIS and DSS?

- ▶ **Executives are not IS specialists:** A CEO should not need to know SQL or navigate complex report menus to get information. EIS must deliver insights through intuitive, graphical interfaces requiring zero technical training.
- ▶ **Executives need speed:** Top management makes many decisions under time pressure. EIS delivers the critical few pieces of information needed in seconds — not buried in a 200-page MIS report.

- ▶ **Executives need filtered, high-level information:** Executives are subject to severe information overload from all levels of the organization. EIS filters out the noise — surfacing only exceptions and critical trends requiring executive attention.
- ▶ **Executives need external information:** Strategic decisions depend heavily on external context — competitor moves, macroeconomic trends, regulatory changes, market prices. Unlike MIS (which is internally focused), EIS integrates external data feeds.
- ▶ **Executives need flexibility:** No two strategic situations are identical. Executives need to explore data in unpredictable directions — EIS must support ad-hoc exploration without requiring new reports to be programmed.

5. EIS Features

Drill-Down Capability

Start with a high-level summary; click to reveal progressively more detail. The executive controls how deep to go.

Example: Total Revenue ₹450Cr → by Division → by Region → by Product → by Customer → to individual transactions. The executive stops drilling when they have enough context to act.

Exception Highlighting

Critical variances are automatically flagged — red for danger, amber for warning, green for on-track.

Executives see instantly what needs attention without scanning every metric.

Example: All KPIs shown as colour-coded indicators.

Red: Customer churn +3% above threshold. **Amber:** Production cost 4% above budget. **Green:** Revenue on target.

Trend Analysis

Shows how key metrics are moving over time — not just the current value, but the direction and velocity of change. A trend chart reveals whether a problem is getting worse or improving.

Example: Market share is 24% today — is that good or bad? The trend chart showing 27% → 26% → 25% → 24% over 4 quarters tells the executive it is declining — action needed.

Graphical Display

Information presented primarily through charts, graphs, maps, and visual dashboards rather than tables of numbers. Executives absorb visual patterns faster than tabular data.

Examples: geo-maps showing revenue heat by region; sparklines showing KPI trends; gauge charts for single KPIs; pie charts for portfolio composition; waterfall charts for financial bridge analysis.

6. EIS Characteristics

- ▶ **User-friendly:** Designed for executives who may have limited computer skills. Touch-screen operation, minimal menus, large text, and intuitive navigation. No training required to use basic functions.

- ▶ **Customizable:** Each executive sees their personal dashboard tailored to their role and priorities. The CFO's EIS emphasizes financial KPIs; the COO's EIS emphasizes operational metrics; the CMO's EIS emphasizes market and customer data.
- ▶ **Integrates external data:** Connects to news feeds (Reuters, Bloomberg), market data services, regulatory announcement feeds, social media sentiment analysis, and competitor pricing intelligence — alongside internal IS data.
- ▶ **Mobile access:** Modern EIS delivers to mobile devices — a CEO can review the company's performance dashboard anywhere in the world. Critical for geographically dispersed enterprises.
- ▶ **Ad-hoc analysis:** Beyond scheduled dashboards, executives can ask unscripted questions and explore data in unexpected directions without waiting for IT to build new reports.

CASE STUDY

Dutch-Bangla Bank: EIS for Executive Performance Monitoring

Context: Dutch-Bangla Bank Limited (DBBL), one of Bangladesh's tech-forward commercial banks, operates hundreds of branches and thousands of ATMs across the country. The Managing Director and senior executives need real-time visibility into the bank's performance without wading through branch-level reports.

EIS Implementation: DBBL's executive dashboard provides:

- **Financial dashboard:** Total deposits, loans outstanding, NPA (Non-Performing Assets) ratio, net interest margin — updated daily. Colour-coded against regulatory limits and internal targets.
- **Operational dashboard:** ATM uptime percentage, mobile banking transaction volume, branch productivity index — updated in near-real-time.
- **Drill-down:** MD sees NPA ratio is 3.2% (amber — above 3% internal target). Drills down to division → sees Corporate Banking NPA at 4.8% is the driver → drills to account level → identifies 3 large accounts requiring immediate recovery action.
- **External data integration:** Bangladesh Bank regulatory announcements, overnight call money market rates, USD/BDT exchange rate — displayed alongside internal metrics for context.

Outcome: Executives who previously received 48-72 hour-old data in thick paper reports now have same-day visibility. Crisis decisions that once required assembling department heads for a 3-hour data-gathering meeting can now be made within 20 minutes of an exception appearing on the EIS dashboard.

Critical Success Factors & TPS/MIS/DSS/EIS Comparison

CO2

Bloom's: Analyze

Teaching: Lecture + Exercise + Q&A

1. Critical Success Factors (CSFs) — Rockart's Method

DEFINITION

Critical Success Factors (CSFs), as defined by John Rockart (MIT, 1979), are the limited number of areas in which results — if satisfactory — will ensure competitive performance for the organization. They represent the things that must go right for a manager or organization to succeed.

CSFs are not the same as goals or objectives. A goal is *what* the organization wants to achieve (e.g., "increase market share by 10%"). A CSF is *what must be done well* to achieve that goal (e.g., "product quality must be consistently high" and "distribution network must reach Tier 2 cities").

ROCKART'S CSF IDENTIFICATION PROCESS

○ Step 1 — Executive Interviews

A trained analyst conducts structured interviews with top executives individually. Each executive is asked: "In your area, what are the factors that are most critical to your success?" and "What are the top 3–5 things that must go right for you to achieve your objectives?" Interview responses are recorded and analysed for patterns.

○ Step 2 — Strategy Alignment

CSFs identified from interviews are mapped against the organization's strategic objectives. Only CSFs directly linked to achieving strategic goals are retained. This ensures that the IS is built around what truly matters strategically — not just operational convenience.

○ Step 3 — Competitive Analysis

Industry-level CSFs are identified by analysing what separates high-performing competitors from underperformers. Some CSFs are universal to an industry (in banking: credit risk management, regulatory compliance, customer trust); others are organization-specific.

○ Step 4 — KPI Identification

For each CSF, measurable KPIs are defined — the specific metrics the IS/DSS/EIS must track and report. Example CSF: "Supplier reliability" → KPIs: on-time delivery rate, defect rate per supplier, supplier response time to quality issues.

○ Step 5 — IS Design

The IS (MIS, DSS, EIS) is designed specifically to monitor and support the identified CSFs and their KPIs. This ensures IS development is business-driven — not technology-driven.

CSF EXAMPLE — RMG (READY-MADE GARMENTS) FACTORY IN BANGLADESH

Strategic objective: Become the preferred sourcing partner for European fashion brands.

CSFs identified through Rockart's process:

- CSF 1: On-time shipment delivery rate $\geq 98\%$ → KPI: % shipments delivered on or before buyer's ex-factory date
- CSF 2: Product quality compliance → KPI: defect rate $< 1.5\%$; audit pass rate $\geq 95\%$
- CSF 3: Ethical compliance (ACCORD/ALLIANCE standards) → KPI: open fire safety findings = 0; child labour incidents = 0
- CSF 4: Cost competitiveness → KPI: CM (Contribution per Minute) $\geq$ industry benchmark; overhead absorption rate
- CSF 5: Buyer relationship quality → KPI: buyer repeat order rate; buyer satisfaction score

IS implication: The factory's MIS must track and report all five CSFs in real-time. The production floor IS monitors CM per minute; the quality IS tracks defect rates per line; the compliance IS tracks audit findings. The EIS rolls all five into a single management dashboard.

2. Complete Comparison — TPS vs. MIS vs. DSS vs. EIS

Dimension	TPS	MIS	DSS	EIS/ESS
Primary users	Operational staff (clerks, cashiers, operators)	Middle managers, department heads	Senior analysts, middle/senior managers	Top executives, C-suite, board
Decision type	Structured — fully proceduralized, no judgment	Structured — predefined reporting rules	Semi-structured — data + model + judgment	Unstructured — strategic, high uncertainty
Primary inputs	Raw transaction events (sales, payments, inventory movements)	TPS transaction summaries, historical data	Internal DB + external data + analytical models	Aggregated internal data + external intelligence + news feeds
Primary outputs	Transaction records, receipts, ledger entries, operational alerts	Scheduled reports, exception reports, demand reports	What-if analyses, scenarios, optimization results, forecasts	Graphical dashboards, KPI scorecards, trend charts, drill-down views

Dimension	TPS	MIS	DSS	EIS/ESS
Processing type	Routine, high-volume, real-time or batch processing	Periodic aggregation and summarization	Interactive, model-based analytical processing	Aggregation + exception detection + external data integration
Time horizon	Present — current transactions	Past and present — historical performance	Present and near-future — scenario analysis	Long-term — strategic trends and future direction
Flexibility	Very low — rigid, proceduralized	Low — predefined report formats	High — interactive, ad-hoc model runs	Very high — executives explore data freely
Support level	Automates decisions — no human judgment in routine transactions	Informs structured decisions — provides data for predefined decisions	Supports semi-structured decisions — augments judgment with models	Supports unstructured decisions — provides context for judgment
Data scope	Narrow — one transaction type at a time	Functional/departmental — one business area	Cross-functional — integrates multiple data sources	Enterprise + external — whole organization plus environment
Bangladesh example	bKash mobile money transfer; Shajgoj e-commerce order processing	Grameenphone monthly subscriber churn report by division	BGMEA export market analysis for pricing negotiations	Bangladesh Bank Governor's macro-financial performance dashboard

EXAM TIP — MASTER THE COMPARISON TABLE

This comparison table is the single most important table in the entire MIS portion of this course. It is tested in almost every exam. Know all 10 dimensions for all four IS types. The most commonly confused pairs are: (1) MIS vs DSS — MIS reports on what happened; DSS explores what could happen; (2) DSS vs EIS — DSS uses models and requires analytical skills; EIS is graphical and requires no IS skills. Practice classifying real-world IS scenarios into the correct category.

3. Integration — How Data Flows Up the Pyramid

The four IS types are not separate, independent systems — they form an integrated pyramid where data flows upward and is transformed at each level:

- ▶ **TPS generates raw data:** Millions of daily transactions create the data reservoir — sales, payments, stock movements, time records.
- ▶ **MIS aggregates TPS data:** The MIS runs nightly or real-time aggregation jobs — summing, grouping, and comparing TPS data against targets to produce management reports.
- ▶ **DSS draws on MIS outputs and TPS data:** When a manager needs to analyse a problem, the DSS accesses both the MIS summary data (for context) and the underlying TPS detail data (for granular analysis) to run models.
- ▶ **EIS draws on all lower levels plus external data:** The EIS aggregates DSS outputs (scenario results), MIS summaries (performance trends), and external data feeds into an executive-level view. It is the apex of the information pyramid.

4. Modern Convergence — Business Intelligence Platforms

In modern organizations, the sharp boundaries between MIS, DSS, and EIS are blurring. Business Intelligence (BI) platforms combine the reporting capabilities of MIS, the analytical models of DSS, and the graphical dashboards of EIS into a single platform accessible at all management levels.

Microsoft Power BI

Connects to dozens of data sources (SQL databases, Excel, cloud services, APIs), provides drag-and-drop report building, interactive dashboards with drill-down, and AI-powered natural language queries ("What were our top 5 products last month?").

Used across all management levels — operational reports, management dashboards, and executive scorecards all within one platform.

Tableau

Leading data visualization platform known for its sophisticated, beautiful visualizations and strong analytical capabilities. Widely used for EIS-style dashboards and DSS-style exploratory analysis.

Particularly powerful for geographic data visualization, trend analysis, and sharing interactive dashboards across the organization.

KEY INSIGHT — BI VS. TRADITIONAL MIS/DSS/EIS

Traditional MIS required the IT department to build every report. DSS required specialist analysts. EIS required expensive custom development for each executive. Modern BI platforms like Power BI and Tableau democratize data analysis — a business analyst with no programming skills can build sophisticated interactive dashboards in hours. This has dramatically reduced the time between "I need this information" and "I have this information."

Marketing, Manufacturing & HR Information Systems

CO2 Bloom's: Understand Teaching: Lecture + Demo + Case Study

1. Marketing Information System

DEFINITION

A **Marketing Information System (Marketing IS)** is a structured set of procedures and methods for the regular, planned collection, analysis, and presentation of information for marketing decision making. It has three subsystems: market research, marketing intelligence, and internal data.

MARKETING IS SUBSYSTEMS

- ▶ **Market Research Subsystem:** Conducts and analyses structured research — surveys, focus groups, experiments, observational studies — to answer specific marketing questions. IS supports: online survey platforms, statistical analysis tools, social listening IS that monitors brand mentions across social media.
- ▶ **Marketing Intelligence Subsystem:** Continuously scans the external environment for competitor activities, market trends, customer behaviour shifts, and regulatory changes. IS supports: news aggregation, competitor price monitoring bots, Google Trends analysis, industry report databases.
- ▶ **Internal Records Subsystem:** Draws on the organization's own TPS and operational IS — sales transactions, customer complaints, website analytics, campaign response rates — to understand market performance.

MARKETING MIX MODELLING (4PS)

Marketing IS supports decision making across all four elements of the marketing mix:

4P Element	IS Support	Key Metrics Tracked
Product	Product lifecycle IS, customer feedback analysis, new product development IS (conjoint analysis, feature prioritization)	Product return rate, customer satisfaction score, NPS by product, feature usage analytics
Price	Dynamic pricing IS (algorithmic real-time price adjustment), competitor price monitoring, price elasticity models in DSS	Price vs. volume trade-off, margin by SKU, price index vs. competitor, promotional lift
Place (Distribution)	Channel performance IS, route-to-market analytics, inventory distribution IS, dealer/retailer performance dashboards	Channel sales mix, distribution reach %, out-of-stock rate by channel, dealer throughput

4P Element	IS Support	Key Metrics Tracked
Promotion	Campaign management IS, marketing attribution models, A/B testing platforms, email marketing automation IS	Campaign ROI, cost per acquisition, click-through rate, conversion rate, media mix efficiency

2. CRM — Customer Relationship Management

DEFINITION

CRM (Customer Relationship Management) is a business strategy and IS that manages the organization's relationships and interactions with current and potential customers, with the goal of improving customer retention, satisfaction, and lifetime value.

Operational CRM

Automates customer-facing processes: sales force automation (tracking leads, opportunities, and deals), marketing automation (email campaigns, lead nurturing), and customer service automation (helpdesk tickets, call centre scripts).

Systems: Salesforce, HubSpot, Zoho CRM. These record every customer interaction and make the history available to any staff member instantly.

Analytical CRM

Analyses customer data to understand behaviour, preferences, and profitability. Uses data mining to segment customers, predict churn, identify cross-sell opportunities, and calculate Customer Lifetime Value (CLV).

CLV = Average Order Value × Purchase Frequency × Customer Lifespan. Analytical CRM identifies which customers have the highest CLV and prioritizes retention efforts accordingly.

Collaborative CRM

Shares customer information across organizational boundaries — between sales, service, and marketing teams, and with external partners. Ensures every touchpoint with the customer benefits from a complete, shared history.

Example: a customer calls the service centre; the agent immediately sees the customer's full purchase history, previous complaints, and current marketing offers from the shared CRM — no need to ask "can you remind me what you bought?"

3. Manufacturing Information System

- ▶ **CAD/CAM Integration:** Computer-Aided Design (CAD) creates digital product designs; Computer-Aided Manufacturing (CAM) translates those designs directly into machine instructions for CNC (Computer Numerical Control) machines. The IS integration between CAD and CAM eliminates manual re-entry of design specifications into manufacturing — reducing errors and cutting product development time.
- ▶ **Production Scheduling IS:** Optimizes the sequencing of jobs through machines to minimize idle time, meet delivery deadlines, and maximize throughput. Uses algorithms (shortest processing time, critical path scheduling) to generate daily/shift production schedules.
- ▶ **Quality Control IS:** Monitors quality metrics at every production stage. Records defect types, defect locations, operator IDs, and timestamps — enabling root cause analysis and process improvement. Statistical Process Control (SPC) IS plots control charts to detect when a process is drifting out of specification before defects occur.

4. MRP — Material Requirements Planning

DEFINITION

MRP (Material Requirements Planning) is a computer-based production planning and inventory control IS that calculates how much raw material and which components are needed, when they are needed, and in what quantities — based on a production plan and a Bill of Materials (BOM).

Net Requirement = Gross Requirement - On-hand Inventory - Scheduled Receipts

Gross Requirement: what production plan demands / On-hand: current stock / Scheduled Receipts: orders already placed

MRP WORKED EXAMPLE

Scenario: A garment factory must produce 500 shirts next week. Each shirt requires 2 metres of fabric (BOM). On-hand fabric inventory: 300 metres. Scheduled receipt from supplier: 200 metres arriving Thursday.

Gross Requirement = 500 shirts × 2 m/shirt = **1,000 metres**

Net Requirement = 1,000 - 300 (on-hand) - 200 (scheduled receipt) = **500 metres**

MRP Output: Place a purchase order for 500 metres of fabric, timed to arrive before production starts — accounting for supplier lead time (e.g., if lead time is 3 days, order must be placed by Monday).

MRP IS runs this calculation automatically for every raw material and sub-component across the entire Bill of Materials — for a complex product with hundreds of components, this would take a human team days to calculate manually. MRP IS does it in minutes.

5. ERP — Enterprise Resource Planning

DEFINITION

ERP (Enterprise Resource Planning) is an integrated IS platform that connects all business functions — Finance, HR, Manufacturing, Sales, Procurement, Supply Chain — into a single unified database and application suite. It eliminates information silos by ensuring all departments share the same real-time data.

ERP Module	Functions	Key Data Shared
Finance & Accounting	General ledger, accounts payable/receivable, fixed asset management, financial reporting	Real-time financial position available to all authorized users
Manufacturing	Production planning, MRP, shop floor control, quality management, CAD/CAM integration	Production orders visible to procurement; quality data visible to sales
Sales & Distribution	Order management, pricing, customer management, shipping, invoicing	Orders trigger automatic inventory reservation and production scheduling
Procurement	Supplier management, purchase orders, goods receipt, invoice verification	Purchase orders reduce procurement cost through spend visibility and consolidation
Human Resources	Payroll, recruitment, training, performance management, time & attendance	Labour costs reflected in financial accounts; skills data available for project staffing

SAP & ORACLE — MARKET LEADERS

SAP (Systems, Applications and Products) and **Oracle** are the two dominant global ERP vendors. SAP S/4HANA and Oracle ERP Cloud are used by most of the world's large corporations. In Bangladesh, Walton, Square Group, PRAN-RFL Group, and major banks use ERP systems. Implementation cost for a large enterprise: USD 5–50 million, taking 1–3 years. Despite the cost, ERP's integration benefits typically deliver ROI within 3–5 years.

6. Human Resource IS (HRIS)

- ▶ **Recruitment IS:** Applicant tracking systems (ATS) manage job postings, application collection, CV screening (including AI-powered keyword matching), interview scheduling, and offer management. Reduces time-to-hire from weeks to days.

- ▶ **Payroll IS:** Calculates employee salaries, deductions (tax, PF, loans), allowances, and overtime — and processes payments automatically. Generates pay slips, tax documents, and statutory compliance reports.
- ▶ **Performance Management IS:** Tracks employee goals (OKRs — Objectives and Key Results), records performance review scores, identifies high performers and underperformers, and links performance data to promotion and compensation decisions.
- ▶ **Training and Development IS:** Tracks training history per employee, identifies skill gaps, schedules training programmes, and measures training effectiveness through post-training assessment scores.

TALENT ANALYTICS

Talent analytics applies data science to HR data to make workforce planning more evidence-based:

- ▶ **Turnover prediction:** Machine learning models trained on historical HR data can predict which employees are at risk of leaving within the next 6 months — based on patterns like lack of recent promotion, salary below market rate, manager dissatisfaction scores, and reduced engagement metrics. HR can intervene proactively with retention offers.
- ▶ **Workforce planning:** HRIS data modelling projects future headcount needs based on business growth plans, retirement rates, and historical attrition — enabling proactive recruitment rather than reactive hiring.

Accounting, Financial & Strategic Information Systems

CO2

Bloom's: Analyze

Teaching: Lecture + Case Study + Discussion

1. Accounting Information System (AIS)

DEFINITION

An **Accounting Information System (AIS)** is a system that collects, records, stores, and processes financial and accounting data to produce information for internal users (management) and external users (investors, regulators, tax authorities).

AIS CORE MODULES

- ▶ **General Ledger (GL):** The master record of all financial transactions classified by account (assets, liabilities, equity, revenues, expenses). Every financial transaction in every other module ultimately posts to the GL. The GL is the source for all financial statements.
- ▶ **Accounts Payable (AP):** Tracks money the company owes to suppliers. Records purchase invoices, matches them against purchase orders and goods receipts (3-way match), and schedules payments. IS automates payment processing and generates ageing reports showing overdue payables.
- ▶ **Accounts Receivable (AR):** Tracks money customers owe the company. Generates invoices, records payments, produces customer account statements, and generates ageing reports showing overdue receivables. AR IS is the foundation of credit management.
- ▶ **Payroll:** Calculates and processes employee compensation. Handles basic salary, allowances, overtime, deductions (income tax, provident fund, loans), net pay calculation, and bank transfer instructions. Generates Form 16 (tax certificates) and statutory compliance reports.
- ▶ **Financial Reporting:** Automatically generates financial statements from GL data — Income Statement (P&L), Balance Sheet, Cash Flow Statement, Statement of Changes in Equity — at any point in time with complete accuracy.

2. Financial Information System

- ▶ **Budgeting IS:** Supports the annual budgeting process — distributing budget templates, consolidating submissions from departments, comparing submissions against strategic targets, performing what-if analysis on budget scenarios, and tracking actual vs. budget in real-time throughout the year.

- ▶ **Cash Flow Forecasting IS:** Projects future cash inflows (collection of receivables, loan proceeds) and outflows (supplier payments, salaries, capital expenditures) on a rolling 13-week basis — enabling proactive cash management to avoid liquidity shortfalls.
- ▶ **Investment Analysis IS:** Supports evaluation of capital investment decisions — calculates NPV, IRR (Internal Rate of Return), and Payback Period for proposed projects. Includes sensitivity analysis to show how investment returns change under different assumptions.
- ▶ **Financial Modelling IS:** Builds dynamic financial models connecting the Income Statement, Balance Sheet, and Cash Flow Statement — allowing planners to see how a change in one variable (e.g., a 5% price increase) flows through all three financial statements.

3. Key Financial Ratios Supported by IS

Financial IS automatically calculates and tracks key financial ratios from AIS data, displaying them on management dashboards:

Ratio	Formula	Interpretation	IS Role
Current Ratio	$\text{Current Assets} \div \text{Current Liabilities}$	Measures short-term liquidity. Ratio > 1 means current assets cover current liabilities. Industry standard typically ≥ 1.5 –2.0.	IS computes daily from AIS; EIS flags if ratio falls below threshold (e.g., 1.2)
Quick Ratio	$(\text{Current Assets} - \text{Inventory}) \div \text{Current Liabilities}$	Stricter liquidity test — excludes inventory (which may not be quickly convertible to cash). Also called Acid-Test Ratio.	IS tracks alongside Current Ratio for early warning of liquidity stress
Net Profit Margin	$\text{Net Profit} \div \text{Revenue} \times 100\%$	Percentage of revenue retained as profit after all expenses. Higher is better. Industry benchmark varies widely.	IS computes monthly from P&L; trends tracked in EIS over time
Debt-to-Equity (D/E)	$\text{Total Debt} \div \text{Total Equity}$	Measures financial leverage. High D/E = high financial risk. Lenders typically require $\text{D/E} \leq 2.0$ for SMEs.	IS monitors for covenant breach — automatic alert if D/E exceeds loan agreement limit
Days Sales Outstanding (DSO)	$(\text{Accounts Receivable} \div \text{Revenue}) \times 365$	Average number of days to collect payment after a sale. Lower DSO = faster cash collection. Target: credit period (e.g., 30 days).	AR IS tracks DSO per customer, per region — identifies slow payers for collection action
Inventory Turnover	$\text{Cost of Goods Sold} \div \text{Average Inventory}$	How many times inventory is sold and replaced per year. Higher = better (less capital tied up in stock).	IS computes from inventory IS + AIS data; low turnover triggers

Ratio	Formula	Interpretation	IS Role
			review of slow-moving stock

FINANCIAL RATIO — WORKED EXAMPLE

Scenario: A textile company's AIS provides: Current Assets = ₪2,40,00,000; Inventory = ₪80,00,000; Current Liabilities = ₪1,20,00,000; Annual Revenue = ₪18,00,00,000; Net Profit = ₪1,44,00,000; Accounts Receivable = ₪3,60,00,000.

Current Ratio = $2,40,00,000 \div 1,20,00,000 = 2.0$ ✓ (Healthy — assets are double the liabilities)

Quick Ratio = $(2,40,00,000 - 80,00,000) \div 1,20,00,000 = 1,60,00,000 \div 1,20,00,000 = 1.33$ ✓ (Adequate)

Net Profit Margin = $(1,44,00,000 \div 18,00,00,000) \times 100\% = 8\%$

DSO = $(3,60,00,000 \div 18,00,00,000) \times 365 = 73$ days ⚠ (If credit terms are 45 days, 73-day DSO signals collection problems)

The Financial IS computes all these ratios automatically, flags DSO as amber (exceeds 45-day policy), and generates a receivables ageing report identifying the overdue customers for the credit manager's action.

4. Strategic Information System (SIS)

DEFINITION

A **Strategic Information System (SIS)** is an IS that is aligned with and directly supports an organization's competitive strategy — not merely automating existing processes, but fundamentally changing the competitive position of the organization in its industry.

CLASSIC SIS EXAMPLES

CLASSIC CASE STUDY

American Airlines' SABRE — IS as a Competitive Weapon

Background: In the 1960s, American Airlines partnered with IBM to build SABRE (Semi-Automated Business Research Environment) — one of the earliest and most famous SIS deployments. SABRE was the first computerized airline reservation system.

Strategic impact: SABRE was installed in travel agent offices and gave those agents direct access to American Airlines' flight availability and booking system. Critically, American Airlines strategically designed SABRE to display its own flights first in every search result — ahead of competitors. Travel agents, who processed the majority of airline bookings, naturally tended to book from the top of the list.

Competitive result: American Airlines gained a significant booking share advantage. Competitors had to scramble to join the system (paying fees to American) or build their own at enormous cost. SABRE became so valuable that it was eventually spun off as a separate company — a technology business worth billions, originally developed as an MIS tool. Today, SABRE still powers reservations for hundreds of airlines.

Lesson: SIS can shift the competitive dynamics of an entire industry. IS is not just a cost — it can be the source of competitive advantage. Competitors who ignore IS may find it has fundamentally changed the rules of competition against them.

CASE STUDY

Walmart's RFID Supply Chain — SIS at Scale

Background: In 2003, Walmart mandated that its top 100 suppliers use RFID (Radio-Frequency Identification) tags on all pallets and cases shipped to Walmart — one of the most ambitious SIS deployments in retail history.

Strategic mechanism: RFID tags allow inventory to be tracked automatically as it moves through the supply chain — from the supplier's factory, through Walmart's distribution centres, to individual store shelves — without manual barcode scanning. Readers at dock doors and store entrances automatically record every movement. This data feeds Walmart's IS in real-time.

Strategic outcomes: Stockout rates at RFID-enabled stores dropped by 16%. Phantom inventory (items recorded as in-stock but actually missing or misplaced) was detected and corrected automatically. Labour costs for inventory management dropped significantly. Walmart's ability to guarantee product availability became a key competitive differentiator against rivals who could not match its supply chain IS investment.

5. Inter-Organizational Systems (IOS)

DEFINITION

An **Inter-Organizational System (IOS)** is an IS that crosses organizational boundaries, enabling electronic information exchange between two or more separate organizations — replacing paper documents, phone calls, and faxes with automated electronic data exchange.

- ▶ **EDI (Electronic Data Interchange):** The original IOS technology — standardized electronic exchange of business documents (purchase orders, invoices, advance shipping notices) in machine-readable format directly between computer systems. No human intervention needed. Bangladesh RMG factories exchange EDI documents with global buyers (H&M, Marks & Spencer) automatically.
- ▶ **Extranet:** A private network that extends an organization's intranet to selected external partners (suppliers, distributors, key customers) — giving them controlled access to specific parts of the

organization's IS. Example: a car manufacturer giving its parts suppliers read access to its production schedule so suppliers can plan their own production proactively.

- ▶ **API-based IOS:** Modern IOS uses REST APIs — software interfaces that allow different organizations' IS to exchange data in real-time over the Internet. Example: bKash's payment API integrated into e-commerce platforms enables instant payment processing without manual intervention.

6. Data Warehousing and OLAP

DATA WAREHOUSE

A **data warehouse** is a large, subject-oriented, integrated, non-volatile, time-variant repository of data, designed specifically to support management decision making (MIS, DSS, EIS) — separate from operational TPS databases to avoid performance interference.

- ▶ **Subject-oriented:** Organized around business subjects (customers, products, sales, suppliers) rather than operational applications (order processing, invoicing).
- ▶ **Integrated:** Combines data from multiple source systems — ERP, CRM, web analytics, external market data — into a consistent, unified format.
- ▶ **Non-volatile:** Once loaded, data is not changed or deleted — the warehouse preserves historical data for trend analysis. The operational TPS can change records; the warehouse keeps the history.
- ▶ **Time-variant:** Contains historical data spanning years — enabling long-term trend analysis impossible with operational systems that only maintain recent data.

OLAP — ONLINE ANALYTICAL PROCESSING

OLAP

OLAP (Online Analytical Processing) is a technology that enables fast, interactive analysis of data along multiple dimensions simultaneously — allowing users to slice, dice, drill-down, roll-up, and pivot data from a data warehouse to gain strategic insights.

OLAP OPERATIONS — EXAMPLE

Data cube dimensions: Time (Year → Quarter → Month → Day), Geography (Country → Division → District → Store), Product (Category → Sub-category → Brand → SKU).

Slice: Take a 2D cross-section — "Show me all sales data for Q3 2024 only" (fixing the Time dimension at Q3 2024).

Dice: Select a sub-cube — "Show me Q3 2024 sales for Electronics in Dhaka Division" (fixing Time, Geography, and Product Category).

Drill-down: Go from aggregate to detail — from "Annual Sales by Division" → click Dhaka → see "Monthly Sales by District in Dhaka" → click Dhanmondi → see "Weekly Sales by Store".

Roll-up: Aggregate from detail to summary — from daily sales → weekly → monthly → quarterly → annual.

Pivot: Rotate the data cube to change perspective — from "Products as rows, Time as columns" to "Time as rows, Products as columns."

STAR SCHEMA CONCEPT

Data warehouses are typically organized using a **star schema**: a central **fact table** (containing measurable business events — each row is a transaction or summary record with numeric measures like quantity sold, revenue, cost) surrounded by **dimension tables** (containing descriptive attributes of the dimensions — customer details, product details, time details, location details). The "star" shape comes from the fact table at the centre with dimension tables radiating outward.

1. Computer Security — Definition

DEFINITION

Computer security (also called Cybersecurity or Information Security) is the practice of protecting information systems, networks, programs, and data from unauthorized access, use, disclosure, alteration, or destruction. The goal is to ensure that IS assets remain secure and available to authorized users while being inaccessible to unauthorized parties.

2. The CIA Triad — Three Pillars of Information Security

Every information security objective maps to one or more of three fundamental properties — together called the CIA Triad:

Confidentiality

Ensuring that information is accessible only to those authorized to access it.

Unauthorized parties must not be able to read, copy, or observe data. Mechanisms: encryption, access control lists, authentication, data classification. Example: a patient's medical records in a hospital IS must be readable by the treating doctor but not by billing staff or other patients. A breach of confidentiality = data leak.

Integrity

Ensuring that information is accurate, complete, and not tampered with by unauthorized parties.

Data must be trustworthy — modifications must only be made by authorized users through authorized processes. Mechanisms: hashing (SHA-256 verifies file integrity), digital signatures, access controls preventing unauthorized writes, audit logs. Example: if an attacker changes a ₹10,000 bank transfer to ₹10,00,000, integrity is violated. A breach of integrity = data tampering.

Availability

Ensuring that authorized users can access information and IS resources when needed.

Systems must be operational and responsive. Mechanisms: redundancy, failover systems, backups, DDoS protection, disaster recovery plans, UPS (Uninterruptible Power Supply). Example: a bank's online banking IS going down during business hours violates availability — customers cannot transact even though the data is safe. A breach of availability = service disruption.

EXAM TIP — CIA TRIAD

The CIA Triad is the most fundamental framework in information security. Every attack, every control, every security policy maps to one or more CIA properties. Always be able to: (1) define each property, (2) give an example of a violation of each, (3) name a control mechanism for each. A ransomware attack primarily

violates Availability (and Confidentiality if data is exfiltrated). A data breach primarily violates Confidentiality. A website defacement primarily violates Integrity.

3. Reasons for System Vulnerability

- ▶ **Complexity:** Modern IS contain millions of lines of code and thousands of configuration parameters. Every line of code is a potential vulnerability — bugs, logic errors, and unintended interactions between components create security weaknesses. No software of significant complexity is perfectly secure.
- ▶ **Connectivity:** The very connectivity that makes IS valuable (network access, API integrations, Internet connectivity) also creates attack surfaces. Every network connection is a potential entry point for attackers. Before the Internet era, attacking a computer required physical access. Now, any Internet-connected system can be attacked from anywhere in the world.
- ▶ **Software errors (bugs):** Buffer overflow, SQL injection vulnerabilities, cross-site scripting — coding errors that attackers exploit. The average enterprise application contains multiple high-severity vulnerabilities. Patches (security updates) fix known vulnerabilities, but IS must be actively maintained.
- ▶ **Insider threats:** Authorized users (employees, contractors) who misuse their legitimate access. Insiders are the most dangerous threat actor because they already have access, knowledge of IS architecture, and are trusted. Motivation: financial gain, grievance, coercion by external actors, carelessness.
- ▶ **Physical access:** An attacker with physical access to a server can bypass many software controls — booting from an external device, extracting hard drives, or simply unplugging systems. Physical security is the foundation of IS security.

4. Threat Actors

Hackers

Individuals who probe IS for vulnerabilities, often for intellectual challenge, curiosity, or to expose weaknesses (ethical/white-hat) or for malicious purposes (black-hat). Skill levels range from "script kiddies" (using pre-built tools with no understanding) to elite nation-state-level operators.

Crackers

Hackers who specifically target security controls to gain unauthorized access or break copy protection. The term distinguishes malicious actors from security researchers. Modern usage often subsumes "cracker" into "black-hat hacker."

Insider Threats

Current or former employees, contractors, or business partners who misuse their authorized

Nation-State Actors

Government-sponsored hacking groups with massive resources, advanced tools, and long-term strategic

access. Three types: malicious insiders (deliberate sabotage or theft), negligent insiders (accidentally cause breaches through carelessness), and compromised insiders (credentials stolen by external attackers).

Example: A disgruntled bank employee downloads 50,000 customer records before resigning. A negligent employee clicks a phishing email and installs malware.

objectives — espionage, disruption of critical infrastructure, intellectual property theft. Most sophisticated threat actors.

Example: The 2010 Stuxnet worm — attributed to US/Israeli intelligence — physically destroyed Iranian nuclear centrifuges by compromising industrial control IS.

Cybercriminal Organizations

Organized criminal groups that treat cybercrime as a business — ransomware-as-a-service, large-scale financial fraud, identity theft, corporate espionage for hire. Often operate from jurisdictions with weak cybercrime enforcement.

Example: REvil ransomware group — responsible for attacks on hundreds of organizations globally, demanding millions of dollars in cryptocurrency ransom.

5. Vulnerability Assessment — CVSS

CVE & CVSS

CVE (Common Vulnerabilities and Exposures) is a public database of known software vulnerabilities, each assigned a unique identifier (e.g., CVE-2021-44228 — the "Log4Shell" vulnerability). The **CVSS (Common Vulnerability Scoring System)** assigns each CVE a severity score from 0.0 (no risk) to 10.0 (critical) based on exploitability and impact.

CVSS Score Range	Severity	Example Action
0.0	None	No action required
0.1 – 3.9	Low	Patch in next scheduled maintenance cycle
4.0 – 6.9	Medium	Patch within 30 days; implement mitigating controls
7.0 – 8.9	High	Patch within 7 days; emergency change process
9.0 – 10.0	Critical	Patch immediately — may justify emergency system shutdown until patched

6. Attack Surface

DEFINITION

The **attack surface** of an IS is the total set of points where an unauthorized user can attempt to enter data into, extract data from, or disrupt the system. Reducing the attack surface is a fundamental security principle — disable unused services, close unused ports, remove unnecessary software.

Attack surface components: network interfaces (every open TCP/UDP port), user interfaces (login forms, APIs, web pages), physical access points (USB ports, server room doors), third-party integrations (each connected partner IS is a potential entry point), and human entry points (employees who can be socially engineered).

7. ISO/IEC 27001 — Information Security Management

ISO/IEC 27001 is the international standard for Information Security Management Systems (ISMS). It provides a risk-based framework for establishing, implementing, and continuously improving information security.

ISO 27001 Domain	Key Controls
Access Control	Role-based access, need-to-know principle, privileged account management, MFA
Cryptography	Encryption of data at rest and in transit, key management procedures
Physical & Environmental Security	Secure perimeters, data center access control, equipment disposal procedures
Operations Security	Change management, malware protection, backup procedures, logging and monitoring
Communications Security	Network segmentation, secure transfer policies, network access controls
Incident Management	Incident response plan, reporting procedures, lessons learned process
Business Continuity	Disaster recovery planning, IS continuity planning, redundancy
Compliance	Adherence to legal requirements (GDPR, Bangladesh ICT Act), audit review

Security Breaches, Controls & Countermeasures

CO3 Bloom's: Apply Teaching: Lecture + Case + Visual

1. Types of Threats and Attacks

A. Malware Taxonomy

Malware (malicious software) is any software intentionally designed to disrupt, damage, or gain unauthorized access to a computer system.

Malware Type	How It Works	Example	CIA Property Violated
Virus	Attaches to legitimate programs; replicates when the host program is executed; requires user action to spread	ILOVEYOU (2000) — email attachment destroyed files on millions of computers	Integrity, Availability
Worm	Self-replicates across networks WITHOUT requiring human action; exploits network vulnerabilities	WannaCry (2017) — exploited Windows SMB vulnerability; infected 200,000+ computers in 150 countries	Availability, Integrity
Trojan Horse	Masquerades as legitimate software; installs malicious payload when executed; does not self-replicate	Zeus Trojan — disguised as legitimate software; stole banking credentials from millions	Confidentiality, Integrity
Ransomware	Encrypts victim's files; demands ransom (cryptocurrency) for decryption key	WannaCry, REvil — Bangladesh Bank's systems were targeted in a 2016 SWIFT attack connected to ransomware networks	Availability, Confidentiality
Spyware	Secretly monitors user activity; captures keystrokes, screenshots, browsing history; transmits to attacker	Keyloggers capturing banking credentials; Pegasus spyware (nation-state grade)	Confidentiality
Rootkit	Hides presence of malware from OS and security tools by modifying core OS components; provides persistent privileged access	Sony BMG rootkit (2005) — hidden in music CDs to enforce DRM; created security vulnerabilities	Confidentiality, Integrity
Botnet	Network of infected computers (bots) controlled remotely by	Mirai botnet (2016) — infected IoT devices, launched 620 Gbps	Availability

Malware Type	How It Works	Example	CIA Property Violated
	attacker (botmaster); used for DDoS, spam, credential stuffing	DDoS attack, taking down major websites	

B. Social Engineering

DEFINITION

Social engineering is the psychological manipulation of people into performing actions or disclosing confidential information. It exploits human psychology — trust, authority, urgency, fear — rather than technical vulnerabilities. The most sophisticated technical security can be defeated by a single manipulated employee.

Phishing

Mass-targeted deceptive emails/messages impersonating legitimate entities (banks, IT department, government) to trick recipients into revealing credentials or clicking malicious links. Spear phishing = highly targeted version using personal details about the victim.

Example: Bangladeshi users receive emails claiming to be from Dutch-Bangla Bank asking them to "verify their account" — link leads to fake DBBL website that harvests credentials.

Pretexting

Attacker creates a fabricated scenario (pretext) to extract information. Impersonates IT support, auditors, vendors, or executives. More elaborate and believable than basic phishing because a detailed fake backstory is constructed.

Example: Caller claims to be from the IT helpdesk, says the target's account was flagged for suspicious activity, asks them to "confirm" their password to re-secure it.

Baiting

Physical or digital lure exploiting human curiosity. Infected USB drives left in parking lots — curious employees plug them in and infect the corporate network. Online bait: free software downloads, pirated content containing malware.

Vishing (Voice Phishing)

Phone-based social engineering. Attacker calls claiming to be from bank fraud department, tax authority (NBR in Bangladesh), or IT support. Creates urgency to pressure victim into revealing information or taking action.

C. Network Attacks

- **Denial of Service (DoS) / DDoS:** Flooding a server with requests beyond its capacity, making it unable to serve legitimate users. DDoS uses thousands of distributed sources (botnet), making it hard to block. Violates Availability. Example: BTCL Bangladesh's servers were disrupted by DDoS during political unrest periods.

- ▶ **SQL Injection:** Inserting malicious SQL code into web form inputs that is then executed by the database. Can expose, alter, or delete entire databases. Example: an attacker types ' OR '1'='1 into a login form to bypass authentication or '; DROP TABLE users; -- to delete all user records.
- ▶ **Man-in-the-Middle (MitM):** Attacker secretly intercepts and possibly alters communications between two parties who believe they are communicating directly. Used on unencrypted public Wi-Fi. HTTPS with certificate validation prevents MitM.
- ▶ **Cross-Site Scripting (XSS):** Injecting malicious client-side scripts into web pages viewed by other users. Can steal session cookies, redirect users, or deface web pages.

2. Security Controls – Classification

Security controls are safeguards implemented to reduce risks. They are classified by **function** and by **implementation type**:

A. By Function (When They Act)

Control Type	Purpose	Examples
Preventive	Stop security incidents from occurring in the first place	Firewalls, access control lists, encryption, security awareness training, multi-factor authentication (MFA), input validation, system hardening
Detective	Identify and alert when a security incident has occurred or is occurring	Intrusion Detection Systems (IDS), audit logs, security cameras, file integrity monitoring (FIM), Security Information & Event Management (SIEM), antivirus scanning
Corrective	Restore systems to normal after a security incident; minimize damage	Data backups and restore procedures, patch management, disaster recovery plans, incident response procedures
Deterrent	Discourage potential attackers from attempting to attack	Warning banners ("Unauthorized access is a criminal offense"), security guards, visible security cameras, legal notices, strong authentication requirements (raises cost of attack)

B. By Implementation Type

Technical Controls Hardware and software mechanisms that enforce security policies automatically, without human intervention once configured. Examples:	Administrative Controls Policies, procedures, guidelines, and training that govern how people and processes interact with IS. The "human" layer of security. Examples:
---	--

- Firewalls (packet filtering, stateful inspection)
- Intrusion Detection/Prevention Systems (IDS/IPS)
- Encryption (AES-256 for data at rest, TLS 1.3 for data in transit)
- Multi-Factor Authentication (MFA) — something you know + something you have
- Antivirus/Anti-malware software
- VPN (Virtual Private Network) for secure remote access
- Patch management systems

- Information Security Policy (ISP) — organization-wide rules for IS use
- Security awareness training programs — teaching employees to recognize phishing
- Acceptable Use Policy (AUP) — rules for using company IS resources
- Background checks on employees with access to sensitive data
- Separation of duties — no single person controls a critical process end-to-end
- Incident response plan — procedures for responding to security events
- Business continuity / disaster recovery planning

Physical Controls

Tangible barriers and mechanisms that control physical access to IS hardware, facilities, and sensitive areas.

Examples:

- Locked server rooms with badge/biometric access — only authorized personnel
- CCTV surveillance cameras in data centers and offices
- Security guards and visitor management procedures
- Cable locks on laptops in shared offices
- Secure disposal of hardware (degaussing hard drives, shredding printed documents)
- UPS and backup power (protects against power-related availability threats)
- Mantrap / airlock access — prevents tailgating into secure areas

3. Defense-in-Depth

DEFINITION

Defense-in-depth (also called layered security) is the principle that multiple independent security controls should be layered such that if one control fails, others still provide protection. No single control is sufficient — an attacker who bypasses one layer encounters the next. Originated from military strategy.

Physical Layer	Locked data center, security guards, biometric access. Stops physical access to hardware. If an attacker gets this far → next layer.
Network Perimeter	Firewall, DMZ (Demilitarized Zone), DDoS protection, IPS. Stops unauthorized network-level access. If traffic gets through → next layer.
Network Segmentation	VLANs, internal firewalls separating HR, finance, operations networks. Limits lateral movement inside the network. Attacker who penetrates one segment cannot automatically reach others.
Host / Endpoint	Antivirus, host-based firewall, endpoint detection & response (EDR), OS patching, application whitelisting. Stops malware executing on individual machines.
Application	Input validation (prevents SQL injection/XSS), secure coding practices, web application firewall (WAF), authentication, session management.
Data	Encryption of data at rest (AES-256) and in transit (TLS), access control (RBAC), data loss prevention (DLP) tools, database activity monitoring. Last line of defense — even if all else fails, encrypted data is useless without the key.

Bangladesh Case Study — bKash Security Model

bKash (Bangladesh's largest MFS provider, 70+ million customers) implements defense-in-depth:

- **Physical:** Tiered data center access with biometrics; servers in secure co-location facilities
- **Perimeter:** Enterprise firewalls, DDoS scrubbing services, intrusion prevention
- **Network:** Payment processing network isolated from customer service networks; internal firewalls
- **Host:** Hardened server images, mandatory patch cycle, antimalware on all endpoints
- **Application:** PIN + OTP for transactions; HTTPS/TLS 1.3; session timeouts; transaction limits
- **Data:** PIN is never stored in plaintext (hashed with bcrypt); transaction records encrypted; ISO/IEC 27001 certified
- **Administrative:** Bangladesh Bank licensing requirements; mandatory security training; background checks on financial staff; real-time fraud monitoring

Result: No single point of failure. A phishing attack that steals a customer's PIN still fails because the attacker needs the physical SIM for the OTP.

EXAM TIP — CONTROLS

Be ready to: (1) classify a given control as preventive/detective/corrective/deterrent AND as technical/administrative/physical — controls can have multiple classifications, (2) explain why defense-in-depth is superior to a single strong control, (3) give Bangladesh-relevant examples. A common exam question: "A bank installs a firewall but an employee emails customer data externally. What control type failed and what would prevent it?" Answer: The firewall (technical/preventive) doesn't stop authorized users. A Data Loss Prevention (DLP) tool (technical/preventive) monitors outbound emails. An Acceptable

Use Policy (administrative/preventive) prohibits it. Separation of duties (administrative) ensures no single employee has access to all customer data.

1. IS Audit — Definition and Importance

DEFINITION

An **IS Audit** (Information Systems Audit) is an independent examination of an organization's information systems, infrastructure, policies, and controls to determine whether they: (1) adequately safeguard assets, (2) maintain data integrity, (3) achieve organizational goals effectively and efficiently, and (4) comply with applicable laws and regulations. IS auditing is a specialized field combining IT expertise with traditional audit methodology.

IS auditing is distinct from general financial auditing in that it focuses specifically on the controls around IS — the systems that process financial and operational data. As all business processes become IT-dependent, IS audit is increasingly critical. Bangladesh Bank mandates IS audits for all scheduled banks under its ICT Security Guidelines.

2. IS Audit Process

01

Planning

Define audit scope, objectives, and boundaries. Identify IS assets in scope. Assess inherent risks. Develop audit plan and assign resources. Determine audit methodology (automated tools vs. manual review). Gain management buy-in.

02

Risk Assessment

Identify and evaluate threats and vulnerabilities relevant to the IS in scope. Prioritize audit areas based on risk level. High-risk areas (e.g., payment processing, customer data) receive more intensive examination. $\text{Risk} = \text{Probability} \times \text{Impact}$.

03

Evidence Gathering

Collect evidence using multiple techniques: interviews with IS staff, document review (policies, procedures), observation (watching processes), re-performance (repeating a control to test if it works), configuration review (examining firewall rules, access control lists), log analysis. Sampling — cannot test 100% of transactions, so audit samples are selected statistically.

04

Testing Controls

Test whether each identified control is: **designed effectively** (the right control for the risk) and **operating effectively** (the control actually works as designed). Penetration testing — ethical hackers attempt to breach the IS to find vulnerabilities before malicious actors do. Vulnerability scanning — automated tools identify known software vulnerabilities.

Reporting

Summarize findings: audit opinions on control effectiveness, list of control deficiencies with risk ratings (critical/high/medium/low), recommendations for remediation. Audit report delivered to senior management and audit committee. Management provides response (accept risk, remediate, transfer). Follow-up audit verifies that findings were addressed.

3. COBIT Framework

COBIT — CONTROL OBJECTIVES FOR INFORMATION AND RELATED TECHNOLOGIES

COBIT is a globally recognized framework developed by ISACA (Information Systems Audit and Control Association) for IT governance and management. It provides a comprehensive set of control objectives, metrics, and maturity models that organizations use to align IT with business objectives, manage IT risks, and ensure compliance. COBIT is the primary framework used by IS auditors.

COBIT 2019 (current version) is organized around **6 governance and management objectives domains**:

COBIT Domain	Focus	Key Questions Addressed
Evaluate, Direct and Monitor (EDM)	Governance — board and senior executive IT oversight	Is IT governance effective? Are IT investments aligned with business strategy? Is risk tolerance defined?
Align, Plan and Organise (APO)	Strategic IT planning and organization	Is IT strategy aligned with business strategy? Are IT risks managed? Is the IT organization structured effectively?
Build, Acquire and Implement (BAI)	IS development, acquisition, and implementation	Are IS projects managed effectively? Is change management in place? Are new systems properly tested?
Deliver, Service and Support (DSS)	IT operations and service delivery	Are IS services reliable and available? Are incidents managed? Are operations secure?
Monitor, Evaluate and Assess (MEA)	Performance monitoring and compliance	Are IS controls effective? Are regulatory requirements met? Is internal audit independent and effective?

COBIT provides **maturity levels** (0–5, based on CMMI) for each domain: 0=Non-existent, 1=Initial (ad hoc), 2=Repeatable, 3=Defined (documented), 4=Managed (measured), 5=Optimized (continuous improvement). IS auditors assess which maturity level an organization has achieved and recommend improvements.

4. Ethical Issues in IS

The pervasiveness of IS creates profound ethical challenges. As CSE professionals who will build and manage IS, you have direct ethical responsibilities for how these systems affect society.

Mason's PAPA Framework

PAPA — FOUR ETHICAL DIMENSIONS OF IS (RICHARD O. MASON, 1986)

Richard Mason identified four categories of ethical issues created by IS, forming the PAPA acronym. Despite being proposed in 1986, PAPA remains highly relevant in the age of big data, AI, and social media.

P — Privacy

What information about oneself should individuals be able to keep private? Who is entitled to access what information and under what conditions?

IS collect, store, and analyze enormous amounts of personal data — location, health, financial, behavioural. The ethical question: when does data collection violate a person's reasonable expectation of privacy?

Issues: Surveillance capitalism (Facebook, Google monetizing personal data), employer monitoring of remote workers, government surveillance, healthcare data breaches, location tracking by mobile apps.

Bangladesh context: bKash, Nagad, and Rocket hold financial transaction histories of 100+ million Bangladeshis. Who should have access? Under what conditions can law enforcement demand this data? What are customers' rights?

A — Accuracy

Who is responsible for the authenticity, fidelity, and accuracy of information? How can we ensure information in IS is correct? Who is accountable when errors occur?

IS decisions are only as good as the data feeding them. Inaccurate IS data can deny people jobs (incorrect background check), deny loans (wrong credit score), or worse — deny medical treatment (wrong patient record).

Issues: Credit bureau errors, AI bias in automated decision systems, medical record errors, electoral roll inaccuracies, fake news propagated by algorithmic recommendation systems.

Bangladesh context: NID (National ID) database errors in Bangladesh have caused citizens to be denied government services, bank accounts, and even passports due to data entry mistakes in the central IS.

P — Property

Who owns information? What are the rights of information creators? How should IS-related intellectual property be handled?

Digital information is infinitely reproducible at near-zero cost — this challenges traditional property concepts. Software, databases, digital music, and algorithms are all forms of intellectual property

A — Accessibility

What information should a person or organization be able to obtain? Under what conditions and with what safeguards should they have access?

IS can simultaneously create information inequality (digital divide) and information overload. The gap between those with and without IS access is a major ethical concern, particularly in developing countries.

protected by copyright and patent law, but easily copied.

Issues: Software piracy, open source licensing compliance, database ownership rights, AI training data (is scraping copyrighted web content for AI training ethical/legal?), trade secret protection in IS.

Bangladesh context: Software piracy rates in Bangladesh remain high. BSA (Business Software Alliance) surveys show significant unlicensed software use, depriving both international and local software developers of revenue and creating security risks (pirated software often contains malware).

Issues: Digital divide (rural vs. urban IS access), website accessibility for persons with disabilities, government information transparency (Right to Information), pay-walls restricting access to knowledge, censorship of online information.

Bangladesh context: Despite a rapidly growing mobile penetration (175 million mobile connections, 2024), rural broadband IS access remains limited. The digital divide means rural populations cannot access government e-services, online banking, or educational resources equally.

EXAM TIP — PAPA FRAMEWORK

For any ethical scenario question, map the issue to PAPA. A scenario involving a company collecting user location data without consent → Privacy. An AI system denying loans based on biased training data → Accuracy (and potentially Property if the training data was scraped without permission). A student downloading pirated textbooks → Property. Government blocking certain websites → Accessibility. Many real scenarios involve multiple PAPA dimensions simultaneously — mention all that apply.

5. Additional Ethical Issues in IS

- ▶ **Algorithmic Accountability:** When AI/ML systems make decisions affecting people (loan approval, hiring, bail recommendations, content moderation), who is accountable for errors or biases? If an algorithm discriminates against a protected group, who is responsible — the programmer, the company, the data scientist?
- ▶ **Digital Labour and Gig Economy:** Platform IS (Pathao, Shohoz, Uber) reshape labour relationships — workers gain flexibility but lose job security, benefits, and labour protections. Is it ethical to classify platform workers as independent contractors to avoid employer obligations?
- ▶ **Environmental Impact of IS:** Data centers consume enormous energy — global data centers used ~200 TWh/year (comparable to entire countries). Cryptocurrency mining is particularly energy-intensive. CSE professionals must consider the environmental footprint of systems they build.
- ▶ **IS and Employment:** Automation and AI are displacing jobs — a 2013 Oxford study estimated 47% of US jobs were at high risk of automation. Who bears the cost of this displacement? What obligations do organizations have to retrain displaced workers?

6. Course Review — BUS 4101 Key Themes

Course Section	Classes	Core Concept	Exam Keywords
E-Commerce Part 1	1–13	Digital commerce — B2B/B2C/C2C models, payment systems (bKash/mobile banking), digital marketing, cybersecurity for commerce, logistics and supply chain	E-commerce models, payment gateways, SEO/SEM, digital marketing funnel, last-mile delivery
MIS Fundamentals	14–20	Data→Information→Knowledge hierarchy, TPS→MIS→DSS→EIS pyramid, system development lifecycle (SDLC), MIS ROI analysis	DIKW, ACID properties, NPV formula, SNR, Kotter's 8-step, SDLC phases
Telecommunications & Networks	21–25	OSI 7-layer model, TCP/IP, Nyquist & Shannon theorems, network topologies, ISP tiers, 5G technologies	OSI layers (remember: Please Do Not Throw Sausage Pizza Away), Nyquist formula, Shannon formula, mesh links formula, eMBB/URLLC/mMTC
Decision Support Systems	26–29	Simon's 4-phase decision model, expected value, decision trees, bounded rationality, DSS types, what-if analysis, EIS features	Intelligence-Design-Choice-Implementation, EV formula, rollback method, CSF method, Rockart's 5 step Balanced Scorecard
Functional IS	30–36	Marketing IS/CRM, manufacturing IS/MRP/ERP, HRIS, AIS/Financial IS, Strategic IS (SABRE, Walmart RFID), Data Warehousing/OLAP	MRP formula (Net Req = Gross – On-hand – Scheduled Receipts), financial ratios, EDI, star schema, OLAP operations
Security & Ethics	37–39	CIA Triad, malware taxonomy, security controls (preventive/detective/corrective), defense-in-depth, IS audit, COBIT, PAPA framework	CIA = Confidentiality/Integrity/Availability, PAPA = Privacy/Accuracy/Property/Accessibility, COBIT domains, Mason's framework

FINAL EXAM STRATEGY

For BUS 4101 exam preparation: (1) Every definition question — give definition, characteristics, and a Bangladesh-relevant example. (2) Every formula — write the formula, define all variables, then apply it to a numerical example. Key formulas to memorize: NPV, Nyquist, Shannon, Mesh Links, Expected Value, MRP Net Requirement, Financial Ratios. (3) Every framework — draw the diagram/model from memory (CIA Triad, DIKW pyramid, OSI stack, Anthony's Triangle, PAPA). (4) Case studies — be ready to apply frameworks (PAPA, CIA, defense-in-depth) to novel scenarios. (5) Comparison questions — be ready to compare TPS vs MIS vs DSS vs EIS, or preventive vs detective vs corrective controls.

BUS 4101 — E-Commerce & Management Information Systems

MIS Notes | Classes 33–39 | Jashore University of Science and Technology

Department of Computer Science & Engineering | Prepared for exam preparation use